CESAR School
Disciplina: **IA para Cibersegurança**
Professor: **Raphael Crespo Pereira**
Turma: **Segurança da Informação**
Período: **4º**
Nome do Aluno**: Mauro Sérgio Rezende da Silva**

Ataques Adversariais de Evasão - Viabilidade no Projeto UEBA

Contexto: a superfície de ataque do nosso UEBA
O atacante relevante é o próprio insider: ele não toca no modelo, só no log que o seu comportamento gera. Isso faz de todos os ataques um cenário de caixa-preta com restrição forte, a exfiltração (USB, cópia, upload) precisa continuar acontecendo.

Componente	O que o modelo vê	Ponto fraco explorável
Perfil UEBA (Parte A)	9 features agregadas por usuário: `n_eventos`, `frac_offhours`, `frac_fds`, `n_usb`, `n_file_copy`, `n_web_upload`, `bytes_out`, `distinct_pcs`, `n_distinct_acoes` → StandardScaler → Isolation Forest (contamination 0.03), LOF, K-Means e ensemble por rank	Frações e somas podem ser diluídas ou fatiadas com ações legítimas
Mineração de processos (Parte C)	Trace por usuário-dia; `surpresa` = média de −log2 p(a→b) das transições; alerta no percentil 99 (344 alertas)	A **média** é diluída por transições comuns inseridas no meio do trace
Avaliação	Precision@k com 47 insiders plantados (gabarito)	Permite medir o sucesso do ataque: o insider sai do top-k ou fica abaixo do p99

Três perguntas guiam cada análise abaixo: acesso necessário (caixa-branca ou preta), validade da entrada (o log continua sendo um log real e a exfiltração ainda funciona) e impacto (insider some da fila do SOC).

Ataque 1 - Modificação manual / troca de canal (MITRE ATLAS)

- **Fonte:** MITRE ATLAS AML.T0043.003 - Craft Adversarial Data: Manual Modification, usada para AML.T0015 - Evade AI Model; caso real AML.CS0003 - Bypassing Cylance's AI Malware Detection, em que uma string benigna anexada ao malware enganou o detector.
- **Como funciona:** o atacante altera à mão, por tentativa e erro, as partes da entrada que ele supõe que o modelo usa, até o alerta sumir.
- **Viabilidade no projeto, alta.** Caixa-preta basta: as features de UEBA são previsíveis (horário, USB, upload). O insider troca `web_upload` por `email_send` (o perfil só soma `bytes` de `web_upload`), age em horário comercial e usa um único PC; a exfiltração continua válida. Impacto: `bytes_out`, `n_web_upload`, `frac_offhours` e `distinct_pcs` ficam normais e o usuário sai do top-20 do `rank_ensemble`.

Ataque 2 - Diluição do perfil (OWASP ML01:2023)

- **Fonte:** OWASP ML Security Top 10 - ML01:2023 Input Manipulation Attack, Cenário #2: manipulação de tráfego para evadir um IDS baseado em ML (texto do draft).
- **Como funciona:** o atacante altera a entrada para que ela caia na região normal do modelo sem perder a função maliciosa.
- **Viabilidade no projeto, alta.** Caixa-preta: o insider infla o denominador das frações com eventos inofensivos em horário comercial (`web_browse`, `file_read`), derrubando `frac_offhours` e `frac_fds` sem tocar na exfiltração. A entrada continua um log válido; o único cuidado é não exagerar em

`n_eventos`, que também é feature. Impacto: queda do score no Isolation Forest e no LOF, tirando o usuário do corte; só `n_usb` e `n_file_copy` continuam o denunciando.

Ataque 3 - Mimicry na sequência de processos (artigo científico)

- **Fonte:** D. Wagner e P. Soto, *Mimicry Attacks on Host-Based Intrusion Detection Systems*, ACM CCS 2002. Contraste clássico de visão: Goodfellow et al., *Explaining and Harnessing Adversarial Examples* (FGSM), 2015.
- **Como funciona:** o atacante insere ações inofensivas ("no-ops semânticos") na sequência maliciosa para que o trace inteiro pareça normal ao detector baseado em sequência.
- **Viabilidade no projeto, média a alta, e é o mais aderente à Parte C.** A `surpresa` é a **média** de −log2 p(a→b); intercalar transições comuns (`web_browse→web_browse`, `logon→web_browse`) entre os passos de exfiltração derruba essa média abaixo do percentil 99. Caixa-preta sobre o grafo directly-follows, que o insider estima observando o próprio dia-a-dia. O trace continua válido (ações reais, só reordenadas/padronizadas) e a cópia→upload permanece. FGSM/PGD, por exigirem gradiente (caixa-branca) e perturbações contínuas, **não** se aplicam a features discretas de contagem, servem só de contraste teórico.

Comparativo e recomendação

Mais fácil de implementar: Ataque 2 (diluição do perfil UEBA). Não exige modelo substituto nem gradiente, só adicionar eventos benignos em horário comercial a um usuário-insider do log e reavaliar o rank_ensemble, cabe numa célula após a Parte A.

Ataque	Acesso	Esforço de implementação	Alvo no projeto	Validade da entrada
1 - Modificação manual / troca de canal	Caixa-preta	Baixo	Features UEBA	Mantida
2 - Diluição do perfil	Caixa-preta	**Muito baixo**	Isolation Forest / LOF	Mantida
3 - Mimicry na sequência	Caixa-preta	Médio	Score de surpresa (Parte C)	Mantida

Como testar o Ataque 2 no notebook, em cerca de 10 linhas:

1. Escolher um `user` com `is_insider = True` que hoje aparece no top-20 da fila.
2. Acrescentar ao `log` dezenas de eventos `web_browse` / `file_read` desse usuário entre 9h e 18h, em dias úteis.
3. Recalcular `perfil`, `X`, os três scores e o `rank_ensemble`.
4. Comparar a posição do usuário e o `precision_at_k` antes e depois, a queda mede o sucesso da evasão.

Defesa a citar na discussão: as três fontes convergem em **treino adversarial** e **validação de entrada**. No nosso caso, somar features robustas à diluição (contagens absolutas de `n_usb` / `n_file_copy`, não só frações) e manter o ensemble UEBA + processos, já que um ataque que engana um raramente engana os dois.

Referências

- MITRE ATLAS - AML.T0043.003 Craft Adversarial Data: Manual Modification
- MITRE ATLAS - AML.CS0003 Bypassing Cylance's AI Malware Detection
- OWASP - ML01:2023 Input Manipulation Attack (draft PDF, Cenário #2 — IDS)
- D. Wagner, P. Soto - Mimicry Attacks on Host-Based Intrusion Detection Systems, ACM CCS 2002
- I. Goodfellow, J. Shlens, C. Szegedy - Explaining and Harnessing Adversarial Examples (FGSM), 2015